

# 中华人民共和国通信行业标准

YD/T 0652—2021

## 移动互联网应用程序（APP）收集使用个人信息最小必要评估规范 第 5 部分：设备信息

Application personal information collection and usage minimization and necessity  
evaluation specification -- Part 5: Device Information

（报批稿）

XXXX – XX – XX 发布

XXXX – XX – XX 实施

中华人民共和国工业和信息化部

发 布

## 目 次

|                             |     |
|-----------------------------|-----|
| 前言 .....                    | II  |
| 引言 .....                    | III |
| 1 范围 .....                  | 4   |
| 2 规范性引用文件 .....             | 4   |
| 3 术语和定义 .....               | 4   |
| 4 缩略语 .....                 | 5   |
| 5 基本原则 .....                | 5   |
| 6 设备信息类型 .....              | 6   |
| 7 设备信息典型收集使用场景 .....        | 6   |
| 8 个人信息处理活动各环节最小必要评估要求 ..... | 6   |
| 8.1 告知同意 .....              | 6   |
| 8.2 收集阶段 .....              | 6   |
| 8.3 存储阶段 .....              | 8   |
| 8.4 使用阶段 .....              | 8   |
| 8.5 提供阶段 .....              | 8   |
| 8.6 删除阶段 .....              | 8   |
| 9 评估方法 .....                | 8   |
| 9.1 告知同意 .....              | 8   |
| 9.2 收集阶段 .....              | 9   |
| 9.3 存储阶段 .....              | 11  |
| 9.4 使用阶段 .....              | 12  |
| 9.5 提供阶段 .....              | 13  |
| 9.6 删除阶段 .....              | 13  |

## 前 言

本文件按照GB/T 1.1—2020《标准化工作导则 第1部分：标准化文件的结构和起草规则》的规定起草。

本文件是YD/T 0648《移动互联网应用程序（APP）收集使用个人信息最小必要评估规范》的第5部分，已经发布了以下部分：

- 第1部分：总则；
- 第2部分：位置信息；
- 第3部分：图片信息；
- 第8部分：录像信息；
- 第10部分：通话记录；
- 第11部分：短信信息；

本文件中的某些内容可能涉及专利。本文件的发布机构不承担识别这些专利的责任。

本文件由中国通信标准化协会提出并归口。

本文件起草单位：中国信息通信研究院、北京字节跳动科技有限公司、北京奇虎科技有限公司、阿里巴巴（中国）有限公司、华为技术有限公司、维沃移动通信有限公司、荣耀终端有限公司、博鼎实华（北京）技术有限公司、北京快手科技有限公司、郑州信大捷安信息技术股份有限公司。

本文件主要起草人：宋恺、王宇晓、杜云、李映婧、杨骁涵、宁华、王艳红、李梦月、安潇羽、田申、刘凯红、孙瑞君、刘陶、武林娜、高震、张吉、姚一楠、黄天宁、衣强、贾科、徐曼、赵晓娜、董小欢、落红卫、刘献伦

# 引 言

随着移动应用种类和数量呈爆发式增长，APP侵害用户权益事件层出不穷，个人信息保护态势愈加严峻，如何保护个人信息，尤其是人脸、通讯录、短信、位置、图片等敏感个人信息受到政府机构和社会公众高度关注。APP收集使用个人信息最小必要评估旨在对移动互联网行业收集使用人脸、通讯录、短信、位置、图片等敏感个人信息进行规范，落实最小、必要的原则。YD/T XXXX拟由16个部分构成：

- 移动互联网应用程序（APP）收集使用个人信息最小必要评估规范 第1部分：总则；
- 移动互联网应用程序（APP）收集使用个人信息最小必要评估规范 第2部分：位置信息；
- 移动互联网应用程序（APP）收集使用个人信息最小必要评估规范 第3部分：图片信息；
- 移动互联网应用程序（APP）收集使用个人信息最小必要评估规范 第4部分：终端通讯录；
- 移动互联网应用程序（APP）收集使用个人信息最小必要评估规范 第5部分：设备信息；
- 移动互联网应用程序（APP）收集使用个人信息最小必要评估规范 第6部分：软件列表；
- 移动互联网应用程序（APP）收集使用个人信息最小必要评估规范 第7部分：人脸信息；
- 移动互联网应用程序（APP）收集使用个人信息最小必要评估规范 第8部分：录像信息；
- 移动互联网应用程序（APP）收集使用个人信息最小必要评估规范 第9部分：录音信息；
- 移动互联网应用程序（APP）收集使用个人信息最小必要评估规范 第10部分：通话记录；
- 移动互联网应用程序（APP）收集使用个人信息最小必要评估规范 第11部分：短信信息；
- 移动互联网应用程序（APP）收集使用个人信息最小必要评估规范 第12部分：好友列表；
- 移动互联网应用程序（APP）收集使用个人信息最小必要评估规范 第13部分：传感器信息；
- 移动互联网应用程序（APP）收集使用个人信息最小必要评估规范 第14部分：应用日志信息；
- 移动互联网应用程序（APP）收集使用个人信息最小必要评估规范 第15部分：身份信息；
- 移动互联网应用程序（APP）收集使用个人信息最小必要评估规范 第16部分：剪切板信息。

# 移动互联网应用程序（APP）收集使用个人信息最小必要评估规范

## 第 5 部分：设备信息

### 1 范围

本文件规定了移动互联网应用程序（APP）在处理涉及用户个人信息（设备信息）的收集、存储、使用、提供、删除等活动中的最小必要评估规范，并通过设备信息在处理活动中的典型应用场景来说明如何落实最小必要原则。

本文件适用于移动互联网应用程序（APP）规范用户个人信息（设备信息）的处理活动，也适用于第三方评估机构等组织对移动互联网应用程序收集使用设备信息行为进行监督、管理和评估，个别条款不适用于特殊行业、专业应用，其他终端也可参考使用。

### 2 规范性引用文件

下列文件中的内容通过文中的规范性引用而构成本文件必不可少的条款。其中，注日期的引用文件，仅该日期对应的版本适用于本文件；不注日期的引用文件，其最新版本（包括所有的修改单）适用于本文件。

YD/T 0648 移动互联网应用程序（APP）收集使用个人信息最小必要评估规范 总则

### 3 术语和定义

下列术语和定义适用于本文件。

#### 3.1

**移动智能终端** smart mobile terminal

能够接入移动通信网，具有能够提供应用软件开发接口的操作系统，具有安装、加载和运行应用软件能力的终端。

#### 3.2

**移动互联网应用程序** mobile application software

能够利用移动智能终端操作系统提供的开发接口，实现某项或某几项特定任务的计算机软件或者代码片段，包含移动智能终端预置应用软件，以及互联网信息服务提供者提供的可以通过网站、应用商店等移动应用分发平台下载、安装、升级的应用软件。

注：本标准中规定的移动互联网应用程序（APP）即为个人信息处理者

[来源：YD/T 0648-2021, 3.2]

#### 3.3

**个人信息** personal information

以电子或者其他方式记录的与已识别或者可识别的自然人有关的各种信息，不包括匿名化处理后的信息。

#### 3.4

**敏感个人信息** personal sensitive information

一旦泄露或者非法使用,可能导致自然人的人格尊严受到侵害或者人身、财产安全受到危害的个人信息,包括生物识别、宗教信仰、特定身份、医疗健康、金融账户、行踪轨迹等信息,以及不满十四周岁未成年人的个人信息。

### 3.5

#### 个人信息的处理 personal information processing

从各种数据元收集个人信息,并从中抽取有价值的信息、知识或智慧的过程,主要包括个人信息的收集、存储、使用、加工、传输、提供、公开、删除等活动。。

[来源: YD/T 0648-2021, 3.6]

### 3.6

#### 个人信息处理者 personal information handler

在个人信息处理活动中自主决定个人信息处理目的、方式等的组织或个人。

### 3.7

#### 收集 collect

通过访问系统接口等方式获取个人信息的行为。

[来源: YD/T 0648-2021, 3.7]

### 3.8

#### 定向推送 directional Push

基于特定个人信息主体的网络浏览历史、兴趣爱好、消费记录和习惯等个人信息,向该个人信息主体推荐或展示信息内容、提供商品或服务的搜索结果以及推送商业广告等活动。

注:业务实践中,定向推送也被称为个性化展示或个性化推荐。本文件中同时使用定向推送、个性化展示和个性化推荐,具有相同含义

[来源: YD/T 0648-2021, 3.11]

## 4 缩略语

下列缩略语适用于本文件。

APP: 应用软件 (Application)

IMEI: 国际移动设备识别码 (International Mobile Equipment Identity)

IDFA: 广告标识符 (Identifier For Advertising)

IDFV: 供应商标识符 (Identifier For Vendor)

GAID: 谷歌广告标识符 (Google Advertising ID)

MEID: 移动设备识别码 (Mobile Equipment Identifier)

OAID: 匿名设备标识符 (Open Anonymous Device Identifier)

CAID: 互联网广告标识 (CAA Advertising ID)

PEI: 永久设备标识符 (Permanent Equipment Identifier)

MCC: 移动设备国家代码 (Mobile Country Code)

MNC: 移动设备网络代码 (Mobile Network Code)

## 5 基本原则

应满足YD/T 0648的最小必要原则。

## 6 设备信息类型

移动智能终端的设备信息类型根据其特性主要包括三类，基本设备信息、不可变设备标识、可变设备标识。

基本设备信息均为设备机型相关信息如品牌、型号等，通常用于功能适配、稳定性等功能，无法单独直接标识用户，不针对此类信息开展最小必要评估。

不可变设备标识在用户正常使用的情况下，修改或重置操作系统设置时，不会随用户操作发生改变，所有应用获取到的值相同。部分终端可生成独立的不可变设备标识符，不可变设备标识的收集通常会受到系统权限机制管控。

可变设备标识在用户正常使用的情况下，修改或重置操作系统设置时，可能会随用户操作行为发生改变，不同应用获取到的值可能不同。

常见设备信息分类见表1。

表 1 设备信息

| 设备信息类别  | 设备信息名称                                                          |
|---------|-----------------------------------------------------------------|
| 不可变设备标识 | IMEI、PEI（5G 系统）、MEID、设备硬件序列号、固定 MAC 地址、固定蓝牙地址等                  |
| 可变设备标识  | Android ID、IDFA、IDFV、GAID、OAID、CAID 等                           |
| 基本设备信息  | 设备厂商名称、设备型号、CPU 型号、处理器架构、存储空间大小、设备操作系统类型、操作系统版本、屏幕分辨率、MCC、MNC 等 |

## 7 设备信息典型收集使用场景

在移动互联网应用程序中设备信息主要用于设备识别等基础服务，间接应用于实际的业务场景或服务。根据设备信息收集使用典型应用场景和业务类型进行分类，主要包括数据统计、消息推送、安全风控、个性化推荐、金融支付、广告营销、系统更新或维修等。

## 8 个人信息处理活动各环节最小必要评估要求

### 8.1 告知同意

告知同意应符合以下要求：

- 个人信息处理者在收集设备信息前应向用户告知并获得授权同意或具备其他合法性基础；
- 如基于同意处理设备信息，收集设备信息前可采用如弹窗提示、提醒勾选、突出链接等适当方式进行告知，告知时机应在收集设备信息前，用户同意后收集设备信息；
- 个人信息保护政策应清晰描述其收集、使用设备信息的目的、方式、范围；
- 个人信息处理者应在申请设备信息相关的系统权限时，向用户告知其用途。

### 8.2 收集阶段

#### 8.2.1 权限申请最小化

权限申请最小化应符合以下要求：

- 个人信息处理者若需申请设备信息相关系统权限，申请时机应在用户使用相关功能或服务时；

- b) 不得因用户拒绝设备信息相关权限而影响其他功能的正常使用，业务功能所必需如查找设备功能等除外；
- c) 用户拒绝后宜间隔48小时及以上再重新申请，用户主动使用相应功能或服务的情况除外。

## 8.2.2 收集信息最小化

a) 个人信息处理者为实现相关功能或服务，需收集不可变设备标识时，应单独征得用户同意并为用户提供有效的开关选项；

b) 个人信息处理者应在保证实现相关功能或服务的前提下，按照最小必要的种类和最低频率收集设备信息。若本地处理设备信息能完成相关功能时，宜优先选择本地处理。

不同产品的业务形态、功能服务效果、移动应用软件开发者能力均可能影响典型应用场景下对设备信息收集使用范围。表2分别给出典型应用场景对应的功能描述、基本功能最小必要收集设备信息字段范围、拓展功能最小必要收集设备信息字段范围，不同系统类别或不同业务功能应在收集时应遵循最小必要原则选择使用。基本功能最小必要收集设备信息字段是指能够基本完成典型应用场景功能时可收集的个人信息范围，个人信息处理者可根据业务形态、功能需求或系统差异自主选择相应功能范围内的个人信息；拓展功能最小必要收集设备信息字段是指为提供典型应用场景下更优的服务效果或更高的稳定性时可收集使用的设备信息范围，个人信息处理者可根据业务形态、功能需求或系统差异自主选择相应功能范围内的个人信息。若收集使用拓展功能可收集范围内字段时，应明确征得用户同意。若业务功能不在表2典型应用场景中的，应按照YD/T 0648要求重新进行评估。

表2 典型应用场景可收集设备信息类别范围

| 典型应用场景 | 功能描述                                                 | 基本功能最小必要收集信息字段（可选）      | 拓展功能可收集信息字段（可选）                 |
|--------|------------------------------------------------------|-------------------------|---------------------------------|
| 功能适配   | 对不同类别的移动智能终端进行功能性适配，主要涉及基本设备信息如屏幕大小、设备厂商、处理器架构等      | 根据具体适配功能，收集其对应的基本设备信息字段 | —                               |
| 数据统计   | 以移动智能终端维度统计数据，数据统计的准确性依赖于收集的设备识别信息类型多少               | Android ID、IDFV         | IMEI/PEI、设备硬件序列号、固定MAC地址        |
| 消息推送   | 将信息推送到目的移动智能终端，收集更多的设备标识可提升推送的精确度和触达率                | Android ID              | IMEI/PEI、设备硬件序列号、固定MAC地址        |
| 安全风控   | 用于风控标记、人机识别、黑产打击等安全风控业务，收集更多的设备标识可提升黑产设备识别率，提供更安全的服务 | Android ID、IDFV         | IMEI/PEI、设备硬件序列号、固定MAC地址、固定蓝牙地址 |
| 个性化推荐  | 用于关联移动智能终端设备维度的用户画像，收集更多的设备标识可提升推荐效果的稳定性             | Android ID、IDFV         | IMEI/PEI、设备硬件序列号、固定MAC地址        |
| 广告营销   | 用于广告投放、效果监测、转化度量、广告反作弊等广告营销功能，收集更多                   | IDFA、GAID、              | IMEI/PEI                        |



|         |                     |                               |   |
|---------|---------------------|-------------------------------|---|
|         | 的设备标识可提升广告营销效果      | OAID、CAID、<br>Android ID、IDFV |   |
| 系统更新/维修 | 用于移动智能终端进行远程控制的相应功能 | IMEI、设备硬件序列号                  | — |

8.3 存储阶段

存储阶段应符合以下要求：

- a) 设备信息的存储时间应在个人信息主体授权的存储时间或提供相关功能或服务所需的必要期限内，超出存储期限后，应及时对设备信息进行删除或匿名化处理，法律法规另有规定的除外；
- b) 若法律法规或行业监管对个人信息存储另有要求的，应遵守其要求。

8.4 使用阶段

使用阶段应符合以下要求：

- a) 设备信息的使用过程及场景应与其告知同意的功能或服务范围一致；
- b) 若需扩大设备信息的使用目的，应在使用前再次告知并经个人信息主体同意后使用；
- c) 对被授权访问用户设备信息的人员，应建立最小授权的访问控制策略，使其只能访问职责所需的最小必要的设备信息，且仅具备完成职责所需的最少的数据操作权限。

8.5 提供阶段

提供阶段应符合以下要求：

- a) 若存在设备信息对外提供的情况，设备信息类型、数量及频次不应超出业务服务的场景范围，法律法规要求的除外。

8.6 删除阶段

删除阶段应符合以下要求：

- a) 个人信息处理者应对超出存储期限的设备信息进行删除或匿名化处理；
- b) 个人信息处理者应提供途径并保证响应并实现用户删除个人信息的要求；
- c) 个人信息处理者应在满足在法律法规的时限或双方约定的时间内及时响应用户删除相关个人信息的请求；如需延长答复用户的时间，应提供合理正当理由。

9 评估方法

9.1 告知同意

|      |                                                                                                                      |
|------|----------------------------------------------------------------------------------------------------------------------|
| 评估编号 | 9.1.1                                                                                                                |
| 评估项目 | 8.1 a) b)                                                                                                            |
| 评估要求 | 个人信息处理者在收集设备信息前应向用户告知并获得授权同意或具备其他合法性基础；<br>如基于同意处理设备信息，收集设备信息前可采用如弹窗提示、提醒勾选、突出链接等适当方式进行告知，告知时机应在收集设备信息前，用户同意后收集设备信息； |
| 预置条件 | 被测APP处于正常状态。                                                                                                         |

|      |                                                                                                                        |
|------|------------------------------------------------------------------------------------------------------------------------|
| 测试步骤 | 1) 核查 APP 是否存在收集设备信息的情况，是否是基于同意处理设备信息<br>2) 若存在基于同意处理设备信息，其收集设备信息前是否通过弹窗提示、提醒勾选等方式对用户进行告知；<br>3) 是否在告知并获得用户同意后才收集设备信息。 |
| 预期结果 | 若以上测试步骤结果为肯定，则测试项判定为未见异常，否则判定为不符合要求。                                                                                   |
| 备注   | --                                                                                                                     |

|      |                                                                                   |
|------|-----------------------------------------------------------------------------------|
| 评估编号 | 9.1.2                                                                             |
| 评估项目 | 8.1 c)                                                                            |
| 评估要求 | 个人信息保护政策应清晰描述其收集、使用设备信息的目的、方式、范围。                                                 |
| 预置条件 | 被测APP处于正常状态。                                                                      |
| 测试步骤 | 1) 核查 APP 的个人信息保护政策，其文字表述是否清晰完整易懂；<br>2) 涉及设备信息收集的，是否能够完整、准确描述其收集使用设备信息的目的、方式、范围。 |
| 预期结果 | 若以上测试步骤结果为肯定，则测试项判定为未见异常，否则判定为不符合要求。                                              |
| 备注   | --                                                                                |

|      |                                                                                        |
|------|----------------------------------------------------------------------------------------|
| 评估编号 | 9.1.3                                                                                  |
| 评估项目 | 8.1 d)                                                                                 |
| 评估要求 | 个人信息处理者应在申请设备信息相关的系统权限时，向用户告知其用途。                                                      |
| 预置条件 | 被测APP处于正常状态。                                                                           |
| 测试步骤 | 1) 核查 APP，依次验证业务功能，查看其是否会申请设备信息相关系统权限；<br>2) 若申请设备信息相关的系统权限，是否会以弹窗文案、蒙层或其他方式来说明本权限的用途。 |
| 预期结果 | 若以上测试步骤结果为肯定，则测试项判定为未见异常，否则判定为不符合要求。                                                   |
| 备注   | --                                                                                     |

## 9.2 收集阶段

|      |                                           |
|------|-------------------------------------------|
| 评估编号 | 9.2.1                                     |
| 评估项目 | 8.2.1 a)                                  |
| 评估要求 | 个人信息处理者若需申请设备信息相关系统权限，申请时机应在用户使用相关功能或服务时。 |
| 预置条件 | 被测APP处于正常状态。                              |
| 测试步骤 | 1) 核查 APP，依次验证业务功能，查看设备信息相关系统权限的申请时机是否在用户 |

|      |                                      |
|------|--------------------------------------|
|      | 使用相关功能或服务时。                          |
| 预期结果 | 若以上测试步骤结果为肯定，则测试项判定为未见异常，否则判定为不符合要求。 |
| 备注   | --                                   |

|      |                                                                                  |
|------|----------------------------------------------------------------------------------|
| 评估编号 | 9.2.2                                                                            |
| 评估项目 | 8.2.1 b)                                                                         |
| 评估要求 | 不得因用户拒绝设备信息相关权限而影响其他功能的正常使用，业务功能所必需如查找设备功能等除外。                                   |
| 预置条件 | 被测APP处于正常状态                                                                      |
| 测试步骤 | 1) 核查 APP 是否会出现拒绝设备信息相关系统权限后无法使用其他功能的情况；<br>2) 若出现 1) 情况，则应判断设备信息相关权限是否为业务功能所必需。 |
| 预期结果 | 若以上测试步骤结果为肯定，则测试项判定为未见异常，否则判定为不符合要求。                                             |
| 备注   | --                                                                               |

|      |                                                                                                               |
|------|---------------------------------------------------------------------------------------------------------------|
| 评估编号 | 9.2.3                                                                                                         |
| 评估项目 | 8.2.1 c)                                                                                                      |
| 评估要求 | 用户拒绝后宜间隔48小时及以上再重新申请，用户主动使用相应功能或服务的情况除外。                                                                      |
| 预置条件 | 被测APP处于正常状态                                                                                                   |
| 测试步骤 | 1) 核查 APP 业务功能，拒绝设备信息相关权限后，再次进入或使用相关功能，查看权限弹窗是否不会再次出现；<br>2) 若未出现 1) 情况，间隔 48 小时内，多次进入或使用相关功能，查看权限弹窗是否不会再次弹出。 |
| 预期结果 | 若以上测试步骤结果为肯定，则测试项判定为未见异常，否则判定为不符合要求。                                                                          |
| 备注   | --                                                                                                            |

|      |                                                                                                                                                         |
|------|---------------------------------------------------------------------------------------------------------------------------------------------------------|
| 评估编号 | 9.2.4                                                                                                                                                   |
| 评估项目 | 8.2.2 a)                                                                                                                                                |
| 评估要求 | 个人信息处理者为实现相关功能或服务，需收集设备标识时，应单独征得用户同意并为用户提供有效的开关选项；                                                                                                      |
| 预置条件 | 被测APP处于正常状态，且设备信息相关功能或服务符合表2典型应用场景内                                                                                                                     |
| 测试步骤 | 1) 核查 APP 收集使用设备信息的相关功能或服务，属于表 2 中哪一类典型应用场景；<br>2) 通过检测工具，检测其收集使用设备信息类型是否不超过表 2 对应典型应用场景中基本功能最小必要收集字段范围；<br>3) 若 2) 情况未出现，进一步查看是否不超出表 2 对应典型应用场景中拓展功能最小 |

|      |                                                                                                            |
|------|------------------------------------------------------------------------------------------------------------|
|      | 必要收集字段范围；<br>4) 若未超出表 2 拓展功能字段范围，则应查看 APP 是否向用户告知其目的方式及用途并明确征得用户同意；<br>5) 结合业务场景，查看其收集频率是否符合实现该功能或服务的最低频率。 |
| 预期结果 | 若以上测试步骤结果为肯定，则测试项判定为未见异常，否则判定为不符合要求。                                                                       |
| 备注   | --                                                                                                         |

|      |                                                                                                                                                                                                                                  |
|------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 评估编号 | 9.2.5                                                                                                                                                                                                                            |
| 评估项目 | 8.2.2 b)                                                                                                                                                                                                                         |
| 评估要求 | 个人信息处理者应在保证实现相关功能或服务的前提下，按照最小必要的种类和最低频率收集设备信息。                                                                                                                                                                                   |
| 预置条件 | 被测APP处于正常状态，且设备信息相关功能或服务符合表2典型应用场景内                                                                                                                                                                                              |
| 测试步骤 | 1) 核查 APP 收集使用设备信息的相关功能或服务，属于表 2 中哪一类典型应用场景；<br>2) 通过检测工具，检测其收集使用设备信息类型是否不超过表 2 对应典型应用场景中基本功能最小必要收集字段范围；<br>3) 若 2) 情况未超过，进一步查看其拓展服务或功能是否不超出表 2 对应典型应用场景中拓展功能最小必要收集字段范围；<br>4) 若未超出表 2 拓展功能字段范围，结合业务场景，查看其收集频率是否符合实现该功能或服务的最低频率。 |
| 预期结果 | 若以上测试步骤结果为肯定，则测试项判定为未见异常，否则判定为不符合要求。                                                                                                                                                                                             |
| 备注   | --                                                                                                                                                                                                                               |

|      |                                                                  |
|------|------------------------------------------------------------------|
| 评估编号 | 9.2.6                                                            |
| 评估项目 | 8.2.2 b)                                                         |
| 评估要求 | 个人信息处理者应在保证实现相关功能或服务的前提下，按照最少必要的种类和最低频率收集设备信息。                   |
| 预置条件 | 被测APP处于正常状态，设备信息相关功能或服务不在表2典型应用场景内。                              |
| 测试步骤 | 1) 核查 APP 收集使用设备信息的功能，并按照 YD/T 0648-2021 的要求评估其处理行为是否满足最小必要相关要求。 |
| 预期结果 | 若以上测试步骤结果为肯定，则测试项判定为未见异常，否则判定为不符合要求。                             |
| 备注   | --                                                               |

|      |       |
|------|-------|
| 评估编号 | 9.2.6 |
| 评估项目 | 8.2.2 |

|      |                                                                            |
|------|----------------------------------------------------------------------------|
| 评估要求 | 个人信息处理者应在保证实现相关功能或服务的前提下，按照最少必要的种类和最低频率收集设备信息。若本地处理设备信息能完成相关功能时，宜优先选择本地处理。 |
| 预置条件 | 被测APP处于正常状态。                                                               |
| 测试步骤 | 1) 核查 APP 收集使用设备信息的功能，判断其是否可以通过本地处理完成；<br>2) 若可完成，查看其是否通过本地处理实现功能。         |
| 预期结果 | 若以上测试步骤结果为肯定，则测试项判定为未见异常，否则判定为不符合要求。                                       |
| 备注   | --                                                                         |

### 9.3 存储阶段

|      |                                                                                    |
|------|------------------------------------------------------------------------------------|
| 评估编号 | 9.3.1                                                                              |
| 评估项目 | 8.3 a)                                                                             |
| 评估要求 | 设备信息的存储时间应在个人信息主体授权的存储时间或提供相关功能或服务所需的必要期限内，超出存储期限后，应及时对设备信息进行删除或匿名化处理，法律法规另有规定的除外。 |
| 预置条件 | 被测APP处于正常状态                                                                        |
| 测试步骤 | 1) 核查设备信息的存储时间是否在个人信息主体授权时间内；<br>2) 核查超出存储期限的设备信息是否及时进行删除或匿名化处理。                   |
| 预期结果 | 若以上测试步骤结果为肯定，则测试项判定为未见异常，否则判定为不符合要求。                                               |
| 备注   | --                                                                                 |

|      |                                                                        |
|------|------------------------------------------------------------------------|
| 评估编号 | 9.3.2                                                                  |
| 评估项目 | 8.3 b)                                                                 |
| 评估要求 | 若法律法规或行业监管对个人信息存储另有要求的，应遵守其要求。                                         |
| 预置条件 | 被测APP处于正常状态。                                                           |
| 测试步骤 | 1) 核查 APP 处理设备信息是否涉及到特殊行业或特殊监管要求；<br>2) 若涉及，则应按照其他法律法规或行业监管的存储要求，开展评估。 |
| 预期结果 | 若以上测试步骤结果为肯定，则测试项判定为未见异常，否则判定为不符合要求。                                   |
| 备注   | --                                                                     |

### 9.4 使用阶段

|      |                                                                     |
|------|---------------------------------------------------------------------|
| 评估编号 | 9.4.1                                                               |
| 评估项目 | 8.4 a) b)                                                           |
| 评估要求 | 设备信息的使用过程及场景应与其告知同意的功能或服务范围一致；若需扩大设备信息的使用目的，应在使用前再次告知并经个人信息主体同意后使用。 |

|      |                                                                            |
|------|----------------------------------------------------------------------------|
| 预置条件 | 被测APP处于正常状态。                                                               |
| 测试步骤 | 1) 运行 APP, 核查 APP 使用信息的功能是否与告知内容一致;<br>2) 若存在扩大使用目的的情况, 则核查是否再次向个人告知并征得同意。 |
| 预期结果 | 若以上测试步骤结果为肯定, 则测试项判定为未见异常, 否则判定为不符合要求。                                     |
| 备注   | --                                                                         |

|      |                                                                              |
|------|------------------------------------------------------------------------------|
| 评估编号 | 9.4.2                                                                        |
| 评估项目 | 8.4 c)                                                                       |
| 评估要求 | 对被授权访问用户设备信息的人员, 应建立最小授权的访问控制策略, 使其只能访问职责所需的最小必要的设备信息, 且仅具备完成职责所需的最少的数据操作权限。 |
| 预置条件 | 被测APP处于正常状态。                                                                 |
| 测试步骤 | 1) 查看当前设备信息对应的授权访问控制策略;<br>2) 授权访问控制策略, 是否有效, 能达到最小必要访问设备信息及数据操作权限目的。        |
| 预期结果 | 若以上测试步骤结果为肯定, 则测试项判定为未见异常, 否则判定为不符合要求。                                       |
| 备注   | --                                                                           |

### 9.5 提供阶段

|      |                                                                                                                                                                                                     |
|------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 评估编号 | 9.5.1                                                                                                                                                                                               |
| 评估项目 | 8.5 a)                                                                                                                                                                                              |
| 评估要求 | 若存在设备信息对外提供的情况, 设备信息类型、数量及频次不应超出业务服务的场景范围, 法律法规要求的除外。                                                                                                                                               |
| 预置条件 | 被测APP处于正常状态。                                                                                                                                                                                        |
| 测试步骤 | 1) 核查 APP 所接入的其他个人信息处理者的功能, 判断其他个人信息处理者处理信息的场景是否为表 2 的典型场景, 处理的信息是否在可收集信息范围内;<br>2) 若其他个人信息处理者的应用场景不属于典型场景或超过可收集信息范围, 则按照 YD/T 0648-2021 的要求评估收集行为是否满足最小必要;<br>3) 运行 APP, 检查 APP 所提供的信息是否与其告知的内容一致。 |
| 预期结果 | 若以上测试步骤结果为肯定, 则测试项判定为未见异常, 否则判定为不符合要求。                                                                                                                                                              |
| 备注   | --                                                                                                                                                                                                  |

### 9.6 删除阶段

|      |        |
|------|--------|
| 评估编号 | 9.6.1  |
| 评估项目 | 8.6 a) |

|      |                                                              |
|------|--------------------------------------------------------------|
| 评估要求 | 个人信息处理者应对超出存储期限的设备信息进行删除或匿名化处理。                              |
| 预置条件 | 被测APP存在存储设备信息的功能。                                            |
| 测试步骤 | 1) 核查 APP 存储设备信息的管理策略, 判断信息超过保存期限后, APP 是否对信息提供了必要的删除或匿名化处理。 |
| 预期结果 | 若以上测试步骤结果为肯定, 则测试项判定为未见异常, 否则判定为不符合要求。                       |
| 备注   | --                                                           |

|      |                                                             |
|------|-------------------------------------------------------------|
| 评估编号 | 9.6.2                                                       |
| 评估项目 | 8.6 b)                                                      |
| 评估要求 | 个人信息处理者应提供途径并保证响应并实现用户删除个人信息的要求。                            |
| 预置条件 | 被测APP存在用户删除个人信息的渠道。                                         |
| 测试步骤 | 1) 核查 APP 是否提供途径用于用户删除个人信息;<br>2) APP 提供的途径是否能够保证正常响应用户的要求。 |
| 预期结果 | 若以上测试步骤结果为肯定, 则测试项判定为未见异常, 否则判定为不符合要求。                      |
| 备注   | --                                                          |

|      |                                                                        |
|------|------------------------------------------------------------------------|
| 评估编号 | 9.6.3                                                                  |
| 评估项目 | 8.6 c)                                                                 |
| 评估要求 | 个人信息处理者应在满足在法律规定的时限或双方约定的时间内及时响应用户删除相关个人信息的请求; 如需延长答复用户的时间, 应提供合理正当理由。 |
| 预置条件 | 被测APP存在用户删除个人信息的渠道。                                                    |
| 测试步骤 | 1) 核查 APP 是否在规定时间及时响应用户的删除请求;<br>2) 若存在其他需要延长答复的情况, 应给向用户提供合理正当理由。     |
| 预期结果 | 若以上测试步骤结果为肯定, 则测试项判定为未见异常, 否则判定为不符合要求。                                 |
| 备注   | --                                                                     |

### 参考文献

- [1] GB/T 35273 信息安全技术 个人信息安全规范
- [2] 中华人民共和国网络安全法(2016年11月7日第十二届全国人民代表大会常务委员会第二十四次会议通过)
- [3] 中华人民共和国个人信息保护法(2021年8月20日第十三届全国人民代表大会常务委员会第三十次会议通过)
- [4] 中华人民共和国数据安全法(2021年6月10日第十三届全国人民代表大会常务委员会第二十九次会议通过)
- [5] 电信和互联网个人信息主体个人信息保护规定(2013年7月16日中华人民共和国工业和信息化部令第24号公布)